Control Questions — Simple Answers

Secure REST API Development with CI/CD and Real CVE Vulnerability Analysis

李泽涛 / LiZetao | HDU 23320332 | Group 23320113 | Variant N/A | 19 October 2026

Q1. Why use bcrypt instead of SHA-256 for passwords?

SHA-256 is fast, so a computer can try billions of passwords per second. bcrypt is slow on purpose, adds a random salt, and its cost can be raised. This makes stolen passwords much harder to crack. SHA-256 is fine for checking file integrity, not for storing passwords.

Q2. What is the difference between SAST and DAST?

SAST checks the source code without running the app. It finds problems early, but it can report false alarms. DAST attacks the running app like a hacker. It finds real runtime problems, but it runs later and may miss some code. The two work best together.

Q3. How does a JWT work, and how does the server check it?

A JWT has three parts: header, payload and signature. The payload holds the user id, expiry, issuer and audience. The server checks the signature and these claims before it trusts the token. A JWT is signed, not encrypted, so do not put secrets in it.

Q4. Why should you audit third-party libraries?

Old libraries can have known bugs. Attackers can use them, and one bad package can affect the whole app. Indirect packages can also change without you noticing. Pin versions, scan dependencies, and keep a list of what you use.

Q5. Why use Docker and Vulhub instead of installing vulnerable software directly?

Docker puts the vulnerable app in a box. It cannot harm your main system, and you can delete it when you are done. It also gives everyone the same setup. Vulhub gives ready-made boxes and clear steps. Installing directly can damage your computer.

Q6. What is the difference between a vulnerability and an exploit?

A vulnerability is the weakness. An exploit is the input that uses it. We reproduced the exploit of CVE-2022-29078: one request made the server run id and write pwned.txt, but the page still looked normal.

Q7. Why test the main features after a security fix?

A fix can break normal features. It can also miss another attack path. Regression tests show that the app still works and that the bug is really gone. Here the page still loaded, no pwned.txt was created, and all 21 tests passed.

Q8. How does CVE practice help a pentester or SOC analyst?

Pentesters use CVE examples to build proofs of concept and to check fixes. SOC analysts use them to write detection rules and to decide what to patch first. Practising in a safe lab also teaches careful, minimal testing.